

SOC Fundamentals

Detailed Study Notes • Beginner / Entry-Level Theoretical Certification

Purpose: Build a strong conceptual foundation for Security Operations Center work, with enough depth to understand the vocabulary, frameworks, metrics, detection logic, and decision-making expected in a beginner SOC certification.

Exam focus: 30 multiple-choice questions + 8 matching pairs • 100 points • 70% passing • no hands-on lab.

How to use these notes: Read each section once for understanding, then use the “Exam Triggers” and “Quick Review” points for final revision. Do not memorize definitions without understanding the relationships between them.

Contents

- 1. SOC Operations & Maturity
- 2. Threat Detection Fundamentals
- 3. MITRE ATT&CK; Framework
- 4. SIEM Fundamentals
- 5. Incident Response Lifecycle
- 6. Common Attack Patterns
- 7. SOC Tools & Log Formats
- 8. Cross-Topic Decision Logic
- 9. Exam-Style Practice Questions
- 10. One-Page Final Revision Sheet

1. SOC Operations & Maturity

What is a SOC? A Security Operations Center is a function or team responsible for continuously monitoring an organization's technology environment, detecting suspicious activity, investigating alerts, responding to incidents, and improving defensive capability.

A SOC is not simply a room full of people watching dashboards. It combines **people, processes, technology, intelligence, and metrics**. A mature SOC tries to move from reacting to alerts toward systematic detection, investigation, threat hunting, automation, and continuous improvement.

SOC workflow

Telemetry → Detection → Alert → Triage → Investigation → Incident decision → Containment/Response → Recovery → Lessons learned → Detection improvement.

Telemetry is the raw information collected from endpoints, networks, applications, identity systems, cloud platforms, and other sources. Detection logic turns telemetry into signals. Analysts then decide whether the signal represents benign activity, suspicious activity, or a security incident.

SOC analyst levels

Level	Typical responsibility
L1 / Tier 1	Monitor queues, triage alerts, validate basic indicators, enrich alerts, document findings, escalate when necessary.
L2 / Tier 2	Perform deeper investigation, correlate multiple events, determine scope and impact, investigate endpoints/users, recommend or perform response.
L3 / Tier 3	Advanced investigation, threat hunting, detection engineering, malware analysis, complex incidents, research and improvement.

Important: Tier boundaries vary by organization. An L1 analyst is not “less intelligent”; the role is designed around alert triage and escalation. Some smaller SOC's combine responsibilities.

SOC types

Model	Meaning
Internal SOC	The organization operates its own security monitoring team.
MSSP	Managed Security Service Provider monitors security services for customers.
MDR	Managed Detection and Response emphasizes threat detection, investigation, and response, often with a stronger security-operations focus.

MSSP vs MDR: The terms can overlap in the real world. For an exam, remember that MDR is specifically centered on managed **detection and response**, while MSSP is the broader managed-security-service concept.

SOC maturity

A mature SOC generally has reliable telemetry, documented processes, tuned detections, measurable performance, threat intelligence, repeatable incident response, automation where appropriate, and continuous improvement. A less mature SOC may rely heavily on manual investigation, have inconsistent logging, poorly tuned alerts, or lack clear escalation procedures.

Detection maturity example: “Alert whenever PowerShell runs” is a crude rule. A more mature detection considers context such as parent process, user, host, command-line behavior, prevalence, known administrative activity, and related events.

24x7 staffing

24x7 SOC coverage means security monitoring and response capability exists around the clock. Organizations may achieve this through multiple shifts, follow-the-sun teams, an external provider, on-call escalation, or a combination.

The important issue is not simply having someone awake: the organization needs **defined handoffs, escalation paths, alert ownership, and response expectations.**

SOC metrics

Metric	Meaning
MTTD	Mean Time To Detect — average time between an attack/event occurring and being detected.
MTTR	Mean Time To Respond/Remediate — terminology varies; generally measures how quickly the organization responds to or resolves an incident.
Dwell time	Time an attacker remains in an environment before being detected.

Do not confuse MTTD with dwell time: MTTD is a detection-performance metric; dwell time describes attacker presence before detection. Also note that organizations may define MTTR differently, so read the question wording carefully.

Exam Triggers: L1 = triage/escalate • L2 = investigate • L3 = advanced analysis/hunting • MTTD = detection • MTTR = response/remediation • dwell time = attacker presence before detection.

2. Threat Detection Fundamentals

Threat detection is the process of identifying activity that may represent malicious behavior. Detection can use known indicators, known patterns, statistical or behavioral deviations, threat intelligence, rules, machine learning, or combinations of these.

Signature-based vs anomaly-based detection

Approach	How it works	Strength
Signature-based	Looks for known patterns, signatures, hashes, byte sequences, rules, or other recognizable characteristics.	Effective for known threats
Anomaly-based	Establishes or uses a model of expected behavior and flags significant deviations.	Can identify previously unknown threats

Modern security systems often combine both approaches. For example, a known malicious file hash is a strong signature, while an employee account logging in from an unusual location at an unusual time may be a behavioral anomaly.

IOC vs IOA

Concept	Definition	Examples
IOC — Indicator of Compromise	Observable evidence associated with compromise or malicious activity.	Malicious IP address, suspicious domain
IOA — Indicator of Attack	Observable behavior suggesting an attack is occurring or being attempted.	Credential dumping behavior, unusual P

The distinction is not perfectly universal across vendors, but for beginner SOC exams the key idea is: **IOC = artifact/observable evidence; IOA = behavior/action indicating an attack.**

True/false positives and negatives

Result	Meaning
True Positive (TP)	A detection fires and there really is malicious/suspicious activity.
False Positive (FP)	A detection fires but the activity is benign.
True Negative (TN)	No alert is produced and the activity is actually benign.
False Negative (FN)	Malicious activity occurs but the detection fails to identify it.

SOC teams care about both false positives and false negatives. Too many false positives create **alert fatigue**; excessive false negatives mean threats are being missed. Detection quality is therefore a balance of useful coverage, precision, context, and operational cost.

Precision: Of the alerts produced, how many are actually positive? **Recall:** Of the real malicious events, how many did the detection identify? You may see these concepts described differently depending on the course, but the underlying trade-off is important.

Detection-as-code

Detection-as-code means treating detection logic like software: detections can be written in structured formats, stored in version control, reviewed, tested, deployed, monitored, and updated systematically.

- **Version control:** keep a history of changes to rules.
- **Testing:** validate that a detection fires on intended behavior and avoids obvious benign cases.
- **Review:** changes can be peer-reviewed before deployment.
- **Deployment:** detections can be promoted consistently across environments.
- **Tuning:** use real alert outcomes to improve quality.

Threat intelligence consumption

Threat intelligence provides information that helps defenders understand threats, adversaries, indicators, tactics, techniques, campaigns, and context. Intelligence is useful when it is relevant to the organization's environment and can inform a defensive decision.

A SOC may consume feeds containing malicious domains/IPs/hashes, vulnerability information, adversary techniques, or reports about campaigns. Intelligence should not be blindly trusted: analysts should consider source reliability, freshness, confidence, context, and whether the indicator is still meaningful.

Example: A threat-intelligence feed identifies a malicious IP. A SIEM can compare network logs against the IP, but the analyst should investigate the connection context rather than automatically declaring every match a confirmed compromise.

Exam Triggers: signature = known pattern • anomaly = unusual behavior • IOC = observable evidence • IOA = attack behavior • TP = real threat detected • FP = benign alert • FN = missed threat • detection-as-code = detections managed like software.

3. MITRE ATT&CK; Framework

MITRE ATT&CK; is a knowledge base describing adversary behavior. It is widely used by defenders to organize, describe, map, test, and improve detections and defensive coverage.

Tactics, techniques, sub-techniques, procedures

Level	Meaning	Simple mental model
Tactic	The adversary's objective or goal.	Why?
Technique	A method used to achieve the objective.	How?
Sub-technique	A more specific version of a technique.	Which specific how?
Procedure	A concrete example of how an actor/software has used a technique.	What did they actually do?

For example, **Credential Access** is a tactic. A credential-dumping method can be represented as a technique/sub-technique, while a particular malware family using a particular command or mechanism is an example of a procedure.

Why SOC analysts use ATT&CK;

- Describe attacker behavior using a common vocabulary.
- Map alerts and detections to adversary techniques.
- Identify gaps in defensive coverage.
- Support threat hunting hypotheses.
- Structure purple-team and detection-testing activities.
- Communicate incidents more precisely.

ATT&CK; Navigator

ATT&CK; Navigator is a visualization tool for creating layers over ATT&CK; techniques. A SOC can use a layer to highlight techniques observed in an incident, techniques covered by detections, techniques associated with a threat group, or gaps that require attention.

Think of Navigator as a **map/visualization of ATT&CK; coverage**, not as a SIEM or an automated detection engine.

Data sources

In ATT&CK; terminology, data sources describe the kinds of information that can provide visibility into adversary behavior. Examples include process creation, network traffic, authentication logs, file activity, command execution, and cloud-service events.

This creates an important SOC relationship: **technique** → **observable behavior** → **required telemetry/data source** → **detection**. If you do not collect the right telemetry, you may not be able to detect a technique reliably.

Exam Triggers: tactic = goal • technique = method • sub-technique = specific method • procedure = concrete implementation/example • Navigator = visual ATT&CK; layers • data sources = telemetry needed to observe behavior.

4. SIEM Fundamentals

A SIEM (Security Information and Event Management) platform centralizes security-relevant event data and provides capabilities for searching, correlation, alerting, analysis, dashboards, and investigation. Modern SIEMs may also include analytics, threat intelligence integration, automation, and detection engineering capabilities.

Common log sources

Source	Examples of useful information
Windows / endpoint	Logons, process creation, services, PowerShell, security events, endpoint detections.
Linux	Authentication, system activity, services, processes, shell activity, audit logs.
Network devices	Connections, firewall decisions, VPN activity, routing/security events.
DNS	Domain lookups, clients making requests, unusual domains.
Proxy / web	URLs, HTTP requests, user/device context, web destinations.
Cloud / SaaS	Authentication, API activity, configuration changes, administrative actions.
Identity provider	Logins, MFA events, password changes, privilege changes.

Correlation rules

A correlation rule combines one or more events or conditions to identify a meaningful pattern. Instead of alerting on every failed login, a rule might alert when a user has a large number of failures followed by a successful login from an unusual source.

Correlation can reduce noise by adding context. However, poorly designed rules can produce false positives or miss attacks.

Common SIEM use cases

- Repeated failed logins / possible brute force
- Suspicious privileged-account activity
- Impossible-travel or unusual authentication patterns
- Malware or endpoint alerts correlated with network activity
- Suspicious PowerShell or command execution
- Data exfiltration indicators
- Persistence or account changes
- Threat-intelligence indicator matches

SIEM vs SOAR

SIEM	SOAR
Collects, normalizes, searches, correlates, and analyzes event data.	Orchestrates and automates security workflows and response actions.
Primary focus: visibility, analytics, detection, investigation.	Primary focus: workflow, orchestration, automation, response.
Example: correlate VPN + identity + endpoint events.	Example: enrich an alert, open a case, disable an account, notify an analyst account.

The two can work together. A SIEM may detect a suspicious event; a SOAR platform can automate enrichment and response steps. Not every SIEM is a SOAR and not every SOAR is a SIEM.

Normalization and enrichment

Different devices describe the same concept differently. SIEM pipelines often normalize fields so analysts can search consistently. Enrichment adds context such as asset ownership, user information, geolocation, reputation, or threat-intelligence results.

Example: a raw IP address becomes more useful when the SOC can associate it with a hostname, user, device role, country, and threat-intelligence reputation.

Exam Triggers: SIEM = collect/correlate/analyze logs • correlation = combine events into meaningful patterns • SOAR = automate/orchestrate response • normalization = make fields consistent • enrichment = add context.

5. Incident Response Lifecycle

Incident response is the organized process of preparing for, detecting, analyzing, containing, eradicating, and recovering from security incidents while learning from what happened.

NIST SP 800-61 lifecycle

The classic NIST incident-response model is commonly taught as four broad phases:

Phase	What happens
1. Preparation	Build policies, roles, tools, contacts, logging, backups, playbooks, training, and readiness.
2. Detection & Analysis	Identify possible incidents, validate them, determine scope, impact, affected assets/users, and likely cause.
3. Containment, Eradication & Recovery	Limit damage, remove the cause, restore systems, monitor for recurrence, and return to normal operation.
4. Post-Incident Activity	Document findings, conduct lessons learned, improve controls/detections/processes, and update plans.

Important exam nuance: Some courses present containment, eradication, and recovery as separate operational steps, while NIST's classic high-level model groups them within the third phase. Know both the concepts and the four-phase NIST structure.

Containment strategies

Containment aims to limit damage and prevent an incident from spreading while preserving the ability to investigate. The correct action depends on the situation.

- **Host isolation:** disconnect or isolate a compromised endpoint from the network.
- **Account containment:** disable or restrict a compromised account; reset credentials where appropriate.
- **Network containment:** block malicious destinations, restrict traffic, quarantine segments, or apply temporary firewall controls.
- **Email containment:** remove malicious messages from mailboxes when appropriate.
- **Cloud containment:** revoke sessions/tokens, restrict access, or isolate affected resources.

Containment can have business consequences. For example, immediately shutting down a critical server may stop an attacker but also cause major operational disruption. Analysts should follow incident-response procedures and escalation authority.

Evidence preservation

Evidence preservation is about maintaining information that may help determine what happened and support later investigation. Relevant evidence can include logs, memory, disk artifacts, network captures, suspicious files, authentication records, and timestamps.

- Preserve relevant logs before retention systems overwrite them.
- Record timestamps and time zones.
- Document who collected evidence, when, from where, and how.
- Avoid unnecessary modification of the original evidence.
- Use approved collection and storage procedures.
- Maintain chain-of-custody requirements when applicable.

Forensics and incident response are related but not identical. An incident responder may need evidence to understand and contain an attack; a formal forensic investigation may impose additional evidence-handling requirements.

Lessons learned

A post-incident review asks: What happened? Why did controls fail or succeed? What telemetry was missing? Which alerts were useful? What took too long? What should be changed?

The goal is not simply to blame someone. The goal is to make the organization harder to compromise and faster to detect and respond next time.

Exam Triggers: Preparation → Detection & Analysis → Containment/Eradication/Recovery → Post-Incident Activity. Containment limits damage; eradication removes the cause; recovery restores operations; lessons learned improves future defense.

6. Common Attack Patterns

Phishing

Phishing uses deceptive messages or sites to trick people into revealing information, opening malicious content, transferring money, or performing another attacker-controlled action.

- Common clues: sender/domain mismatch, urgency, unexpected attachments, suspicious links, requests for credentials or payment.
- Technical indicators: unusual URLs, newly registered/suspicious domains, attachment types, redirects, authentication failures.
- SOC response: preserve the message, inspect headers/URLs/files as appropriate, identify affected recipients, search for related messages, and contain compromised accounts/endpoints.

Brute force

Brute-force attacks repeatedly attempt credentials. Related patterns include password spraying, where a small number of common passwords are tried across many accounts.

Pattern	Typical signal
Brute force	Many password attempts against one account or service.
Password spraying	One/few passwords attempted against many accounts.
Credential stuffing	Previously stolen username/password pairs tested against another service.

Detection often relies on authentication logs, source IPs, usernames, failure counts, time windows, successful logins after failures, and contextual information.

Lateral movement

Lateral movement occurs when an attacker moves from an initially compromised system toward additional systems or accounts inside an environment.

Possible signals include unusual remote logons, administrative shares, remote services, credential reuse, abnormal SMB/RDP/SSH activity, or a workstation suddenly communicating with many internal systems.

Key idea: Initial access gets the attacker in; lateral movement helps the attacker reach more valuable systems.

Exfiltration

Exfiltration is the unauthorized transfer of data out of an environment. Defenders may look for unusual outbound volume, rare destinations, unexpected cloud-storage usage, suspicious encrypted channels, unusual protocols, or data transfers outside normal business patterns.

Context matters: a large transfer is not automatically malicious. Backups, software updates, media uploads, and legitimate business processes can create high-volume traffic.

Ransomware behavior

Ransomware commonly attempts to disrupt access to data, often by encrypting files and sometimes by stealing data before encryption. Modern ransomware operations may therefore involve multiple stages: initial access, privilege escalation, credential access, lateral movement, discovery, defense evasion, data collection/exfiltration, and impact.

- Potential indicators: mass file modifications, unusual encryption processes, disabled security controls, deletion of backups/shadow copies, suspicious administrative activity.
- SOC priorities: determine scope, isolate affected systems, protect backups, preserve evidence, identify initial access, and coordinate incident response.

Exam Triggers: phishing = deception/social engineering • brute force = repeated credential attempts • lateral movement = moving internally • exfiltration = data leaving the environment • ransomware = impact through data encryption/disruption, often with preceding attack stages.

7. SOC Tools & Log Formats

Splunk

Splunk is a platform commonly used for searching, analyzing, visualizing, and alerting on machine-generated data. In SOC contexts, it can function as a SIEM or security analytics platform depending on the deployment and products used.

Typical SOC use: search authentication logs, correlate events, build dashboards, investigate suspicious activity, and create detections.

Wireshark

Wireshark is a network protocol analyzer. It can inspect packet captures and decode many network protocols. SOC analysts use it to investigate suspicious connections, protocols, DNS activity, HTTP traffic, TCP behavior, and other network evidence.

Exam clue: If the question says “packet capture,” “PCAP,” or “inspect network packets,” think Wireshark.

VirusTotal

VirusTotal aggregates results and information from many security products and services and provides reputation/context for files, URLs, domains, and IP addresses. It is useful for enrichment, but a detection verdict from a public service should not automatically be treated as absolute proof.

A SOC analyst may submit or search a file hash, domain, URL, or IP to gather additional context. Be careful with sensitive files and organizational data when using public services.

TheHive

TheHive is an incident-response and case-management platform commonly associated with organizing investigations. Analysts can use cases, alerts, observables, tasks, notes, and related workflows to coordinate response.

Exam clue: If the question emphasizes case management, investigation workflow, tasks, and observables, think TheHive.

Syslog

Syslog is a widely used standard for transporting and/or recording system and device log messages. Network appliances, Linux/Unix systems, and other devices may send messages to a central syslog server.

A syslog message commonly contains information such as facility, severity/priority, timestamp, host, and message content, although exact structure varies.

CEF and LEEF

Format	Core idea	Exam association
CEF	Common Event Format, a standardized event format widely used to help security products send structured events to SIEMs.	Security event
LEEF	Log Event Extended Format, associated especially with IBM QRadar and structured event collection.	SIEM event for

Do not confuse a log transport method with a log format. **Syslog** commonly refers to the logging/transport mechanism, while **CEF/LEEF** describe structured event formats.

Sigma rules

Sigma is a generic, open rule format for describing detections in log data. The value of Sigma is portability: a detection can be written in a vendor-neutral form and then translated or adapted for different SIEM/query languages.

A Sigma rule typically contains metadata and a detection definition describing fields/conditions that should trigger. Sigma is not itself a SIEM and does not collect logs.

Exam clue: “vendor-neutral detection rule for logs” → Sigma.

Exam Triggers: Splunk = log search/analysis • Wireshark = packet analysis • VirusTotal = reputation/enrichment • TheHive = case management/IR • Syslog = logging/transport • CEF/LEEF = structured event formats • Sigma = portable detection rule format.

8. Cross-Topic Decision Logic

The hardest beginner SOC questions are often not pure definitions. They give you a situation and ask what concept, tool, metric, or action fits. Use these chains.

Scenario A: suspicious login

You see 80 failed logins followed by one successful login from an unfamiliar IP.

- Data source: authentication logs.
- Possible attack: brute force/password attack.
- Detection: correlation of many failures + success + context.
- IOC possibility: suspicious IP.
- IOA possibility: repeated credential attempts.
- SIEM role: collect/correlate/alert.
- Analyst action: triage and investigate before declaring a confirmed incident.

Scenario B: suspicious PowerShell

A workstation launches PowerShell with an unusual command line from an unexpected parent process.

- Detection type: behavioral/anomaly or rule-based detection.
- Possible ATT&CK; mapping: command/scripting-related technique(s), depending on the exact behavior.
- Data source: process creation / endpoint telemetry.
- Next step: investigate parent-child process chain, user, host, command line, timing, related network activity, and prevalence.
- Do not automatically conclude compromise from one event; add context.

Scenario C: ransomware-like behavior

An endpoint rapidly modifies thousands of files and security controls are being disabled.

- Potential incident: ransomware or destructive activity.
- Immediate priority: containment to limit spread/damage.
- Evidence: preserve relevant endpoint, authentication, network, and file activity logs.
- Investigation: identify initial access, affected accounts/hosts, lateral movement, and possible exfiltration.
- Recovery: restore clean systems/data and verify that the attacker has been removed.

The SOC mental model

1. What happened? Identify the event. **2. Is it malicious?** Validate and enrich. **3. How big is it?** Scope users, hosts, accounts, and data. **4. What should we do now?** Contain according to procedure. **5. What caused it?** Find the attack path. **6. How do we prevent recurrence?** Improve controls and detections.

9. Exam-Style Practice Questions

These are original practice questions based on the published topic list you provided. They are not copied from the CyberExam exam and are intended to test understanding.

1. Which SOC level most commonly performs initial alert triage and escalation?

- A. L1
- B. L2
- C. L3
- D. Executive management

Answer: A — L1 commonly handles first-line triage and escalation.

2. Which metric measures the average time taken to detect an event?

- A. MTTR
- B. MTTD
- C. Dwell time
- D. FP rate

Answer: B — MTTD is Mean Time To Detect.

3. An attacker remains in an environment for 20 days before detection. What concept describes this period?

- A. MTTD
- B. MTTR
- C. Dwell time
- D. Containment

Answer: C — dwell time describes attacker presence before detection.

4. Which is the best example of an IOC?

- A. Unusual credential-dumping behavior
- B. A known malicious file hash
- C. An attacker objective
- D. A SOC playbook

Answer: B — a malicious hash is an observable artifact.

5. Which detection approach is designed around deviations from expected behavior?

- A. Signature-based
- B. Anomaly-based
- C. Hash-only
- D. Static routing

Answer: B.

6. A detection fires for normal administrative activity. What is this?

- A. True positive
- B. False positive
- C. False negative

- D. True negative

Answer: B — the alert fired, but the activity is benign.

7. In ATT&CK, what represents an adversary's goal?

- A. Procedure
- B. Technique
- C. Tactic
- D. Data source

Answer: C — tactic represents the objective.

8. What is ATT&CK; Navigator primarily used for?

- A. Packet capture
- B. Visualizing ATT&CK; techniques and coverage
- C. Password cracking
- D. Email delivery

Answer: B.

9. Which platform is primarily associated with SIEM log searching and analysis?

- A. Wireshark
- B. Splunk
- C. TheHive
- D. VirusTotal

Answer: B.

10. Which technology is primarily associated with automating security workflows and response?

- A. SOAR
- B. Syslog
- C. PCAP
- D. DNS

Answer: A.

11. Which NIST incident-response phase comes before Detection & Analysis?

- A. Preparation
- B. Recovery
- C. Lessons learned
- D. Eradication

Answer: A.

12. Which action best represents containment?

- A. Writing the final report
- B. Isolating a compromised endpoint
- C. Restoring a clean backup
- D. Updating a CV

Answer: B.

13. What does lateral movement describe?

- A. Moving data to a backup
- B. Moving between internal systems after initial access
- C. Encrypting one file
- D. Blocking an IP

Answer: B.

14. What does exfiltration mean?

- A. Unauthorized data transfer out of an environment
- B. Password hashing
- C. Log normalization
- D. Endpoint isolation

Answer: A.

15. Which tool is most directly suited to examining PCAP/network packets?

- A. Wireshark
- B. TheHive
- C. Splunk
- D. VirusTotal

Answer: A.

16. Which format is associated with vendor-neutral detection rules for log data?

- A. Sigma
- B. LEEF
- C. Syslog
- D. PCAP

Answer: A.

Matching Practice

Term	Best match
L1	Alert triage / escalation
L3	Threat hunting / advanced analysis
MTTD	Time to detect
IOC	Observable evidence/artifact
SIEM	Log collection, correlation, analysis
SOAR	Workflow and response automation
Wireshark	Packet analysis
Sigma	Vendor-neutral detection rules

For the real matching section, read every option carefully before matching. Some concepts are intentionally similar.

10. One-Page Final Revision Sheet

Concept	Remember this
SOC	Monitor → detect → investigate → respond → improve
L1	Triage + escalate
L2	Deep investigation
L3	Threat hunting + advanced analysis/detection engineering
Internal SOC	Organization operates its own SOC
MSSP	Managed security services for customers
MDR	Managed detection + response
MTTD	Mean Time To Detect
MTTR	Mean Time To Respond/Remediate (definition can vary)
Dwell time	Attacker time in environment before detection
Signature	Known pattern
Anomaly	Deviation from expected behavior
IOC	Evidence/artifact associated with compromise
IOA	Behavior indicating an attack
TP	Threat detected correctly
FP	Benign activity triggered an alert
FN	Threat missed by detection
ATT&CK tactic	Attacker goal
ATT&CK technique	Method
ATT&CK sub-technique	More specific method
Procedure	Concrete implementation/example
Navigator	Visualize ATT&CK layers/coverage
SIEM	Collect + correlate + analyze logs
SOAR	Orchestrate + automate response
Correlation	Combine events/conditions into a meaningful pattern
NIST IR	Preparation → Detection/Analysis → Containment/Eradication/Recovery → Post-Incident
Phishing	Deception to make a victim perform an attacker-desired action
Brute force	Repeated credential attempts
Lateral movement	Move between internal systems
Exfiltration	Steal/transfer data out
Ransomware	Disrupt/ encrypt data; may include data theft
Splunk	Log search/analysis/SIEM
Wireshark	Packet analysis

Concept	Remember this
VirusTotal	Reputation/enrichment
TheHive	IR case management
Syslog	Common logging/transport mechanism
CEF	Common structured security event format
LEEF	Structured event format associated with QRadar
Sigma	Portable/vendor-neutral detection rule format

Final exam advice: The exam is theoretical, so focus on distinctions. If two answers both sound plausible, look for the one that exactly matches the definition in the question. Pay particular attention to *IOC vs IOA*, *SIEM vs SOAR*, *MTTD vs MTTR vs dwell time*, *tactic vs technique*, and *FP vs FN*.

These notes are a study guide, not an official CyberExam answer key. Terminology can vary slightly between vendors and organizations; when the question gives a specific definition, follow the definition used in the question.